

Article view endpoint can be abused to inflate reads

Severity: Medium

Evidence: backend/src/controllers/articleController.ts:497-575

Risk: Anonymous clients can repeatedly POST view events, inflating stats and causing database write load.

Recommendation: Add IP/user rate limits, anonymous dedupe window, capped timeSpentSeconds, and optional bot/captcha protection for suspicious bursts.

2FA recovery codes are shorter than recommended

Severity: Medium

Evidence: backend/src/utils/totp.ts:101-110

Risk: Current recovery codes are 32-bit each, which is weaker than typical backup-code entropy.

Recommendation: Generate stronger one-time recovery codes, for example 10 to 16 random bytes per code, and keep only hashes in the database.

Disabling 2FA does not revoke active refresh sessions

Severity: Medium

Evidence: backend/src/controllers/authController.ts:481-534

Risk: Existing sessions remain valid after a major security setting changes.

Recommendation: Revoke all refresh sessions after enabling/disabling 2FA, password reset, role changes, bans, and other high-risk account actions.

Dormant data processing functions could be dangerous if exposed later

Severity: Medium

Evidence: backend/src/services/dataProcessing.ts:13-257

Risk: The service can export or deactivate accounts based only on email if a future route calls it without strong verification.

Recommendation: Remove unused dangerous functions or require authenticated/verified identity plus admin approval and audit logging.

Low Risk

Frontend dependency advisory for Quill

Severity: Low

Evidence: npm audit --omit=dev in frontend reports quill XSS advisory through react-quill-new

Risk: Rich text editor dependency has a known low-severity advisory.

Recommendation: Track upstream fix, update when compatible, and keep server-side article sanitization as the primary defense.